

CET104 – UFCD9192

Final Assignment No. 1 of Vulnerability Analysis Module - Initiation



Work carried out by: João Manuel de Carvalho Cordeiro – N° 36203

Table of Contents

Contents

Final Assignment No. 1 of Vulnerability Analysis Module - Initiation	1
Introduction	3
Objectives	3
Statement / Exercises	4
Kali.....	5
Download PCAP and EXE Executable.....	6
Download Wireshark	7
Identification of the infected machine	8
Exercise 1: IP, MAC Address and Hostname of the infected machine	9
Exercise 2: User Account of the Infected Machine	10
Exercise 3: IP used in the "delivery" of the infection	11
Exercise 4: SHA256 hash of the EXE executable file.....	12
Exercise 5: Type of Malware that infected the machine	14
Exercise 6: IP of the host that infected the machine	15
Exercise 7: Domain of the host that infected the machine.....	16
Bibliography	17
Conclusion	18

Introduction

This work focuses on the forensic analysis of a network traffic capture (PCAP file) and a malicious executable file, with the aim of investigating a security incident.

Initially, I downloaded the PCAP file and executable to Kali Linux, ensuring that the executable file would not be opened or executed at any time.

With the files safely in the environment, I proceeded with the investigation using Wireshark to analyze network traffic and command-line tools to perform static analysis of the executable file. The evidence allowed us to answer the seven questions of the statement.

Objectives

The main objectives of this work were:

- Develop skills in forensic analysis of network traffic.
- Identify indicators of compromise in PCAP captures.
- Practice static analysis of executable files in a secure way.
- Understand malware attacks and techniques.
- Document evidence in a clear and methodological way.
- First contact with security incident investigation.

I believe that these objectives have been successfully achieved, as I will detail in the conclusion.

Statement / Exercises

Exercise 1:

What is the IP, MAC address and hostname of the infected Windows machine?

Exercise 2:

What is the user account of the infected Windows machine?

Exercise 3:

What is the ip used in the "delivery" of this infection?

Exercise 4:

What is the hash of the SHA256 executable file (EXE) taken from the infected system?

Exercise 5:

Based on the alerts, what kind of malware infected this Windows system?

Exercise 6:

What is the ip of the host that infected Windows?

Exercise 7:

What is the domain of the host that infected the system?

If you don't want to see the settings/downloads you can go to page [8](#).

Kali

For this work I will use the kali from a previous work with few settings.
I installed his OVA like this:

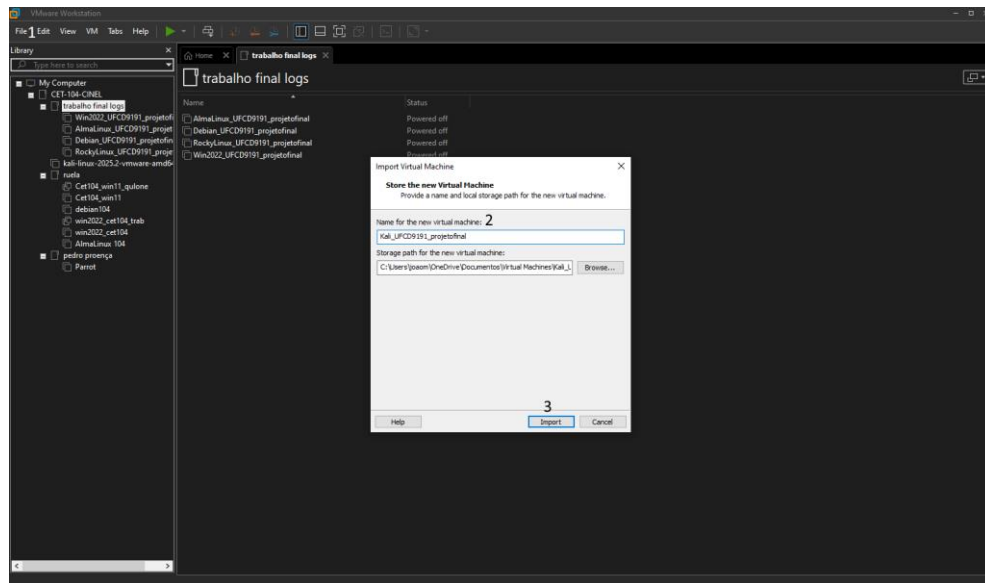


Figura 1 Criação do Kali Ova

1-Select "Open" and open the kali OVA. 2- Give a name. 3- Click "Import".

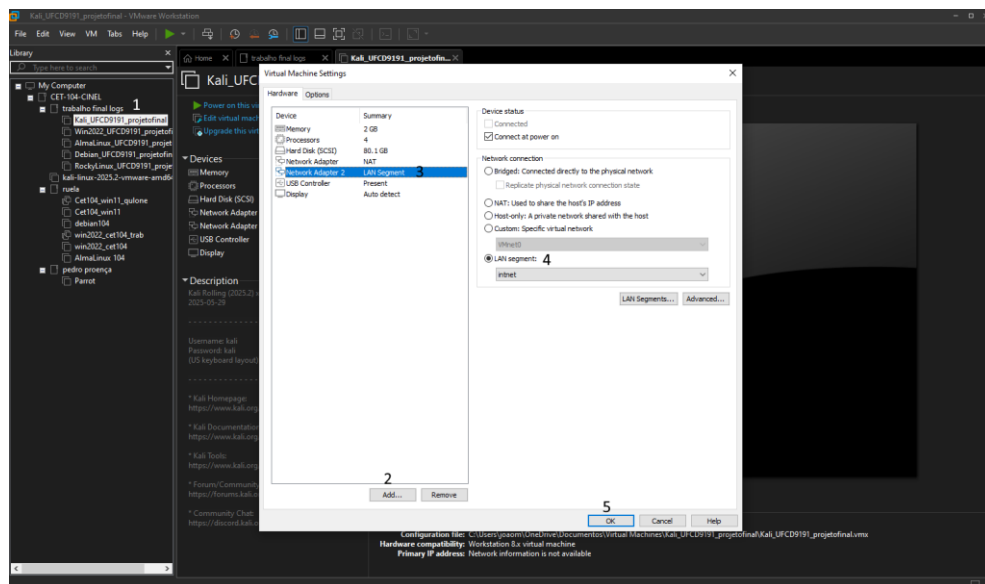


Figura 2 Criação do Kali Ova

1-Select the created machine and with the right mouse button click on "Settings".
2- Click on "Add" and add a "Network Adapter". 3-Click on "Network Adapter 2".
4-Click on "LAN Segment" and select the "intnet" segment. 5-Click "OK".

Download PCAP and EXE Executable

As indicated, I will install the PCAP and EXE Executable files provided by the trainer through the email.

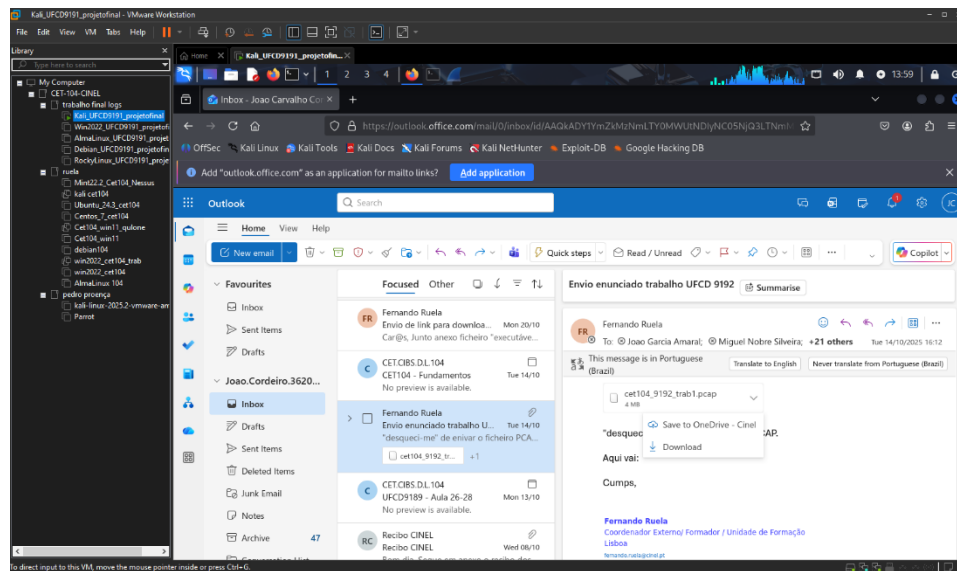


Figura 3 Download do PCAP

This executable file is only to be used in exercise 4 for SHA256 and should not be opened/executed.

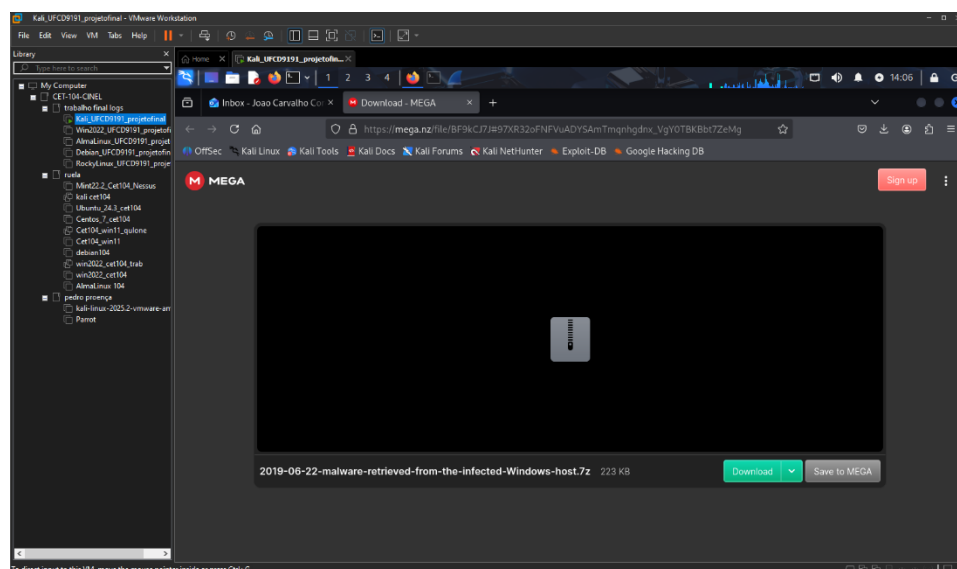
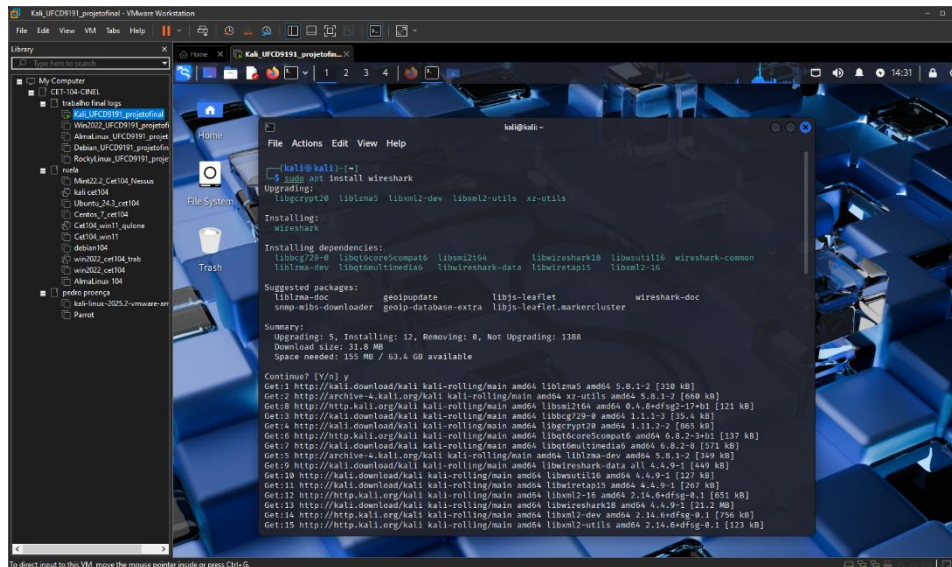


Figura 4 Download do Executável EXE

Download Wireshark

If your machine does not have Wireshark, you can install with this process:



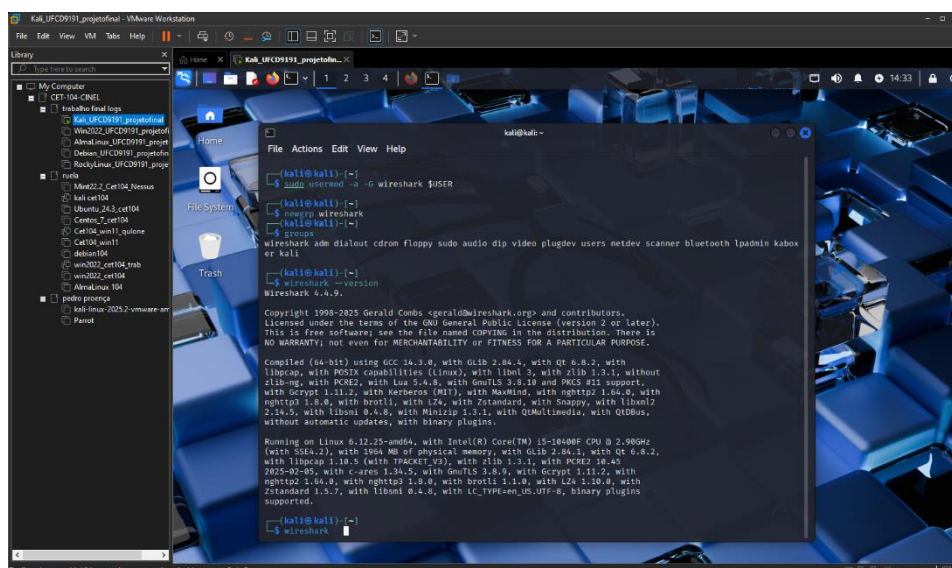
```
kali@kali:~$ sudo apt install wireshark
Upgrading:
libncurses6 libbz2-dev libxml2-utils xz-utils
Installing:
wireshark
Installing dependencies:
libbrotli-dev libbrotli1-dev libbrotli1-dev libbrotli1-dev libbrotli1-dev
libbrotli1-dev libbrotli1-dev libbrotli1-dev libbrotli1-dev libbrotli1-dev
Suggested packages:
libbrotli1-dev libbrotli1-dev libbrotli1-dev libbrotli1-dev libbrotli1-dev
Summary:
Upgrading: 5, Installing: 12, Removing: 0, Not Upgrading: 1388
Download size: 31.8 MB
Space needed: 155 MB / 63.4 GB available

Continue? [Y/n] y
Get:1 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:4 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:5 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:6 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:7 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:8 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:9 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:10 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:11 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:12 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:13 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:14 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
Get:15 http://kali.download/kali kali-rolling/main amd64 libbrotli1-dev amd64 1.0.7-2 [110 kB]
```

Figura 5 Download Wireshark

If a screen appears warning of extra settings during installation, select "Yes".

The user is then given permissions to use wireshark correctly:



```
kali@kali:~$ sudo usermod -s -c wireshark $USER
kali@kali:~$ newgrp wireshark
kali@kali:~$ groups
wireshark adm dialout cdrom floppy sudo audio dip video plugdev users netdev scanner bluetooth lpadmin kbox
er kali
kali@kali:~$ wireshark --version
Wireshark 4.4.9
Copyright 1998-2025 Gerald Combs <gerald@wireshark.org> and contributors.
Licensed under the terms of the GNU General Public License (version 2 or later).
This is free software; see the file named COPYING in the distribution. There is
NO WARRANTY; not even for MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE.

Compiled (64-bit) using GCC 14.3.0, with Glib 2.84.4, with Qt 6.8.2, with
libcap, with POSIX capabilities (Linux), with libltdl 3, with zlib 1.3.1, without
zlib-ng, with PCRE2, with Lua 5.4.8, with GnuTLS 3.8.10 and PKCS #11 support,
with crypt 1.11.2, with Verbsus (HID), with WavPack, with nghttp2 1.64.0, with
nghttp3 1.6.0, with brotli, with LZ4, with Zstandard, with Snappy, with libxml2
2.14.0, with libxml 0.4.0, with libzip 3.3.2, with QMidi, with QDBus,
without automatic updates, with binary plugins.

Running on Linux 6.12.25-amd64, with Intel(R) Core(TM) i5-10400P CPU @ 2.90GHz
(with SSE4.2), with 1606 MB of physical memory, with Glib 2.84.4, with Qt 6.8.2,
with libcap 1.10.5 (with TRACETEST), with zlib 1.3.1, with PKCS #11 support,
with crypt 1.11.2, with Verbsus 1.34.5, with GnuTLS 3.8.9, with crypt 1.11.2, with
nghttp2 1.64.0, with nghttp3 1.6.0, with brotli 1.1.0, with LZ4 1.10.0, with
Zstandard 1.5.7, with libxml 0.4.0, with libzip 3.3.2, with libcap 1.10.5, binary plugins
supported.

kali@kali:~$ wireshark
```

Figura 6 Permissões do Wireshark

Then you just need to type "wireshark" on the command line to open wireshark.

Identification of the infected machine

First, it was necessary to identify the infected machine.

Using the alert image in the traffic provided by the trainer, several errors were detected, including indications of infection.

Src IP	SPort	Dst IP	DPort	Pr	Event Message
35.226.156.55	443	10.0.76.193	49207	6	ET POLICY Lets Encrypt Free SSL Cert Observed
10.0.76.109	49204	37.46.135.170	80	6	ET CURRENT_EVENTS RIG EK URI Struct Jun 13 2017
37.46.135.170	80	10.0.76.109	49204	6	ETPRO CURRENT_EVENTS RIG EK Landing Apr 04 2017 M5
37.46.135.170	80	10.0.76.109	49204	6	ET INFO Suspicious Possible CollectGarbage in base64 1
37.46.135.170	80	10.0.76.109	49204	6	ET INFO Obfuscated fromCharCode
10.0.76.109	49203	37.46.135.170	80	6	ET CURRENT_EVENTS RIG EK URI Struct Mar 13 2017 M2
10.0.76.109	49203	37.46.135.170	80	6	ET POLICY Outdated Flash Version M1
37.46.135.170	80	10.0.76.109	49203	6	ETPRO CURRENT_EVENTS RIG EK Flash Exploit Sep 05 2017 (FWS)
10.0.76.109	49209	8.209.83.76	80	6	ET TROJAN Generic gate[.].php GET with minimal headers
10.0.76.109	49211	8.209.83.76	80	6	ET TROJAN Trojan Generic - POST To gate.php with no referer
10.0.76.109	49211	8.209.83.76	80	6	ETPRO TROJAN KPOT Stealer Exfiltration M2
10.0.76.109	49211	8.209.83.76	80	6	ET TROJAN Trojan Generic - POST To gate.php with no accept headers
74.125.138.1...	80	10.0.76.193	49216	6	GPL WEB_CLIENT web bug 0x0 gif attempt
35.226.156.55	80	10.0.76.193	49261	6	GPL WEB_CLIENT web bug 0x0 gif attempt

Figura 1 Alertas encontrado no tráfego

Figura 7 Alertas encontrados no tráfego fornecidos pelo formador

The IP address 10.0.76.109 has been identified as the infected machine, based on the following malicious sequence of events:

1) Host 10.0.76.109 has initiated communication with malicious IP 37.46.135.170 (port 80). Multiple alerts associated with the RIG Exploit Kit were generated, including:

- ET CURRENT_EVENTS RIG EK URI Struct
- ETPRO CURRENT_EVENTS RIG EK Landing
- ET POLICY Outdated Flash Version
- ETPRO CURRENT_EVENTS RIG EK Flash Exploit

These alerts indicate that 10.0.76.109 visited a malicious landing page that exploited a vulnerability (most likely in Adobe Flash) to compromise the system.

2) Immediately after, the same host 10.0.76.109 started communicating with another malicious IP, 8.209.83.76 (port 80).

You have connected to a gate.php file, a common Command & Control (C2) endpoint. The critical ETPRO TROJAN KPOT Stealer Exfiltration M2 alert was triggered, confirming that the specific malware installed on the system was KPOT Stealer, a Trojan designed to steal information.

With this we confirm that host 10.0.76.109 is infected, with host 37.46.135.170 being the culprit.

This information will be important for the next exercises.

Exercise 1: IP, MAC Address and Hostname of the infected machine

I'm going to look for the host information 10.0.76.109 with the "dhcp" filter.

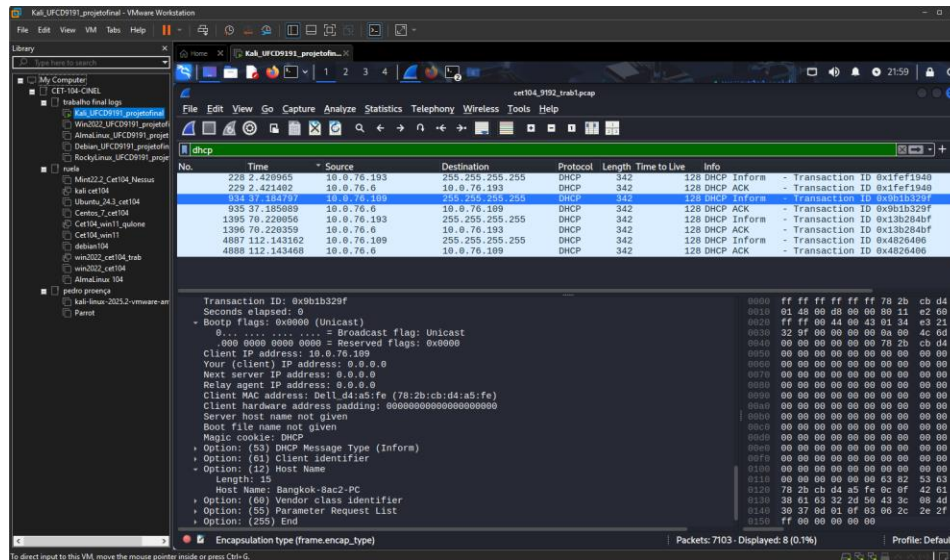


Figura 8 IP, MAC Address e Hostname do 10.0.76.109

Within the "Dynamic Host Configuration Protocol" we can check the IP, MAC Address and Hostname of the machine:

Bootp flags: 0x0000 → Client IP Address: 10.0.76.109

Bootp flags: 0x0000 → Client MAC address: 78:2b:cb:d4:a5:fe

Option: (12) Host Name → Host Name: Bangkok-8ac2-PC

You can also see that I activated an extra column of "Time To Live" that confirms if the machine is windows or another, in this case 128 is windows.

Exercise 2: User Account of the Infected Machine

Using the filter "(ntlmssp|| kerberos) && ip.addr == 10.0.76.109", navigating to:
Kerberos → as-req → req-body → cname → cname-string: 1 item →
CNameString: bangkok-8ac2-pc\$

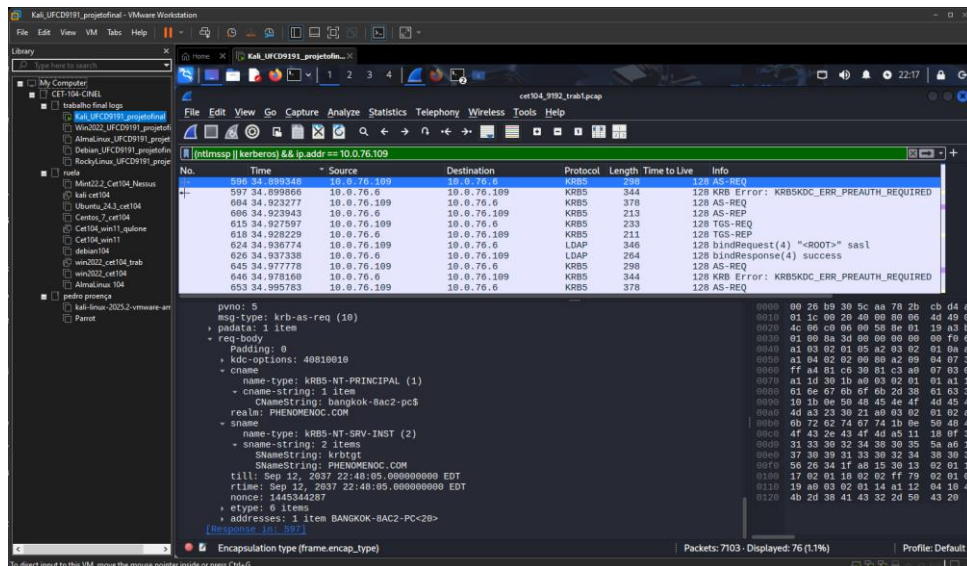


Figura 9 Conta do 10.0.76.109

This way we check the user account of the infected machine.

Exercise 3: IP used in the "delivery" of the infection

As you had seen before in the "Infected machine identification" section, this attack targeted the host 10.0.76.109 and the attacker sent malicious files directly to infect it.

In short, the ip used in the delivery of the infection was 37.46.135.170 as it sent malicious files to a machine on the network.

And it can be said that the host 8.209.83.76 is the final delivery point where the stolen information is collected.

Exercise 4: SHA256 hash of the EXE executable file

For this exercise it is important to be very careful not to run the malware test file, the goal being to extract it and perform SHA256.

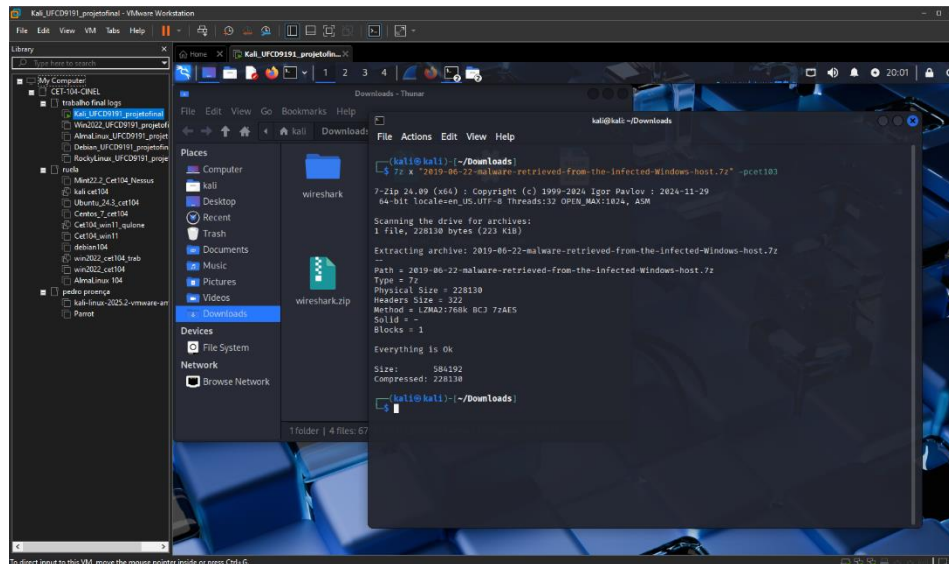


Figura 10 Extração do ficheiro Malware

After extracted, we will perform the SHA256

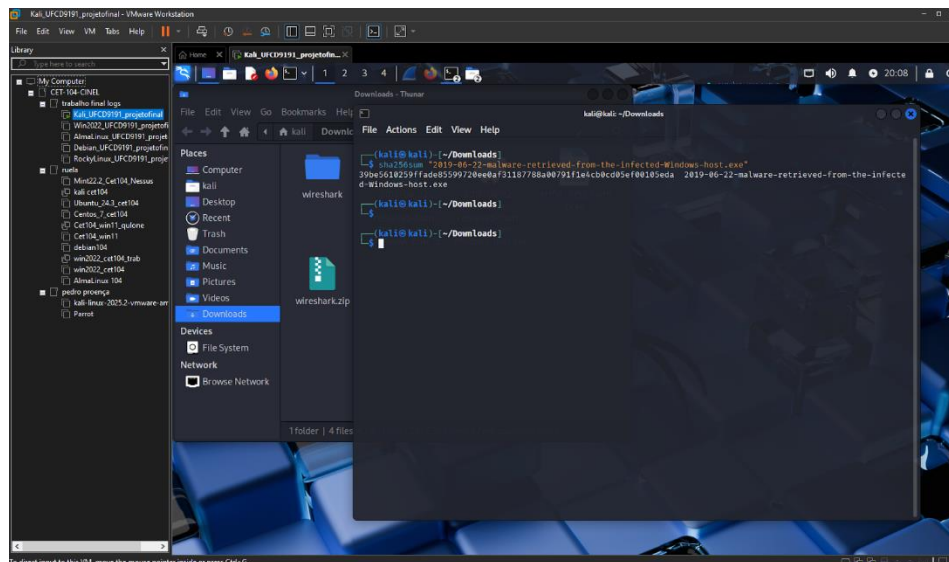


Figura 11 SHA256 do ficheiro .exe do Malware

File SHA256: 39be5610259ffade85599720ee0af31187788a00791f1e4cb0cd05ef00105eda

One can also check (using the extracted sha) the danger of this malware file on the website:
<https://www.virustotal.com/gui/home/search>.

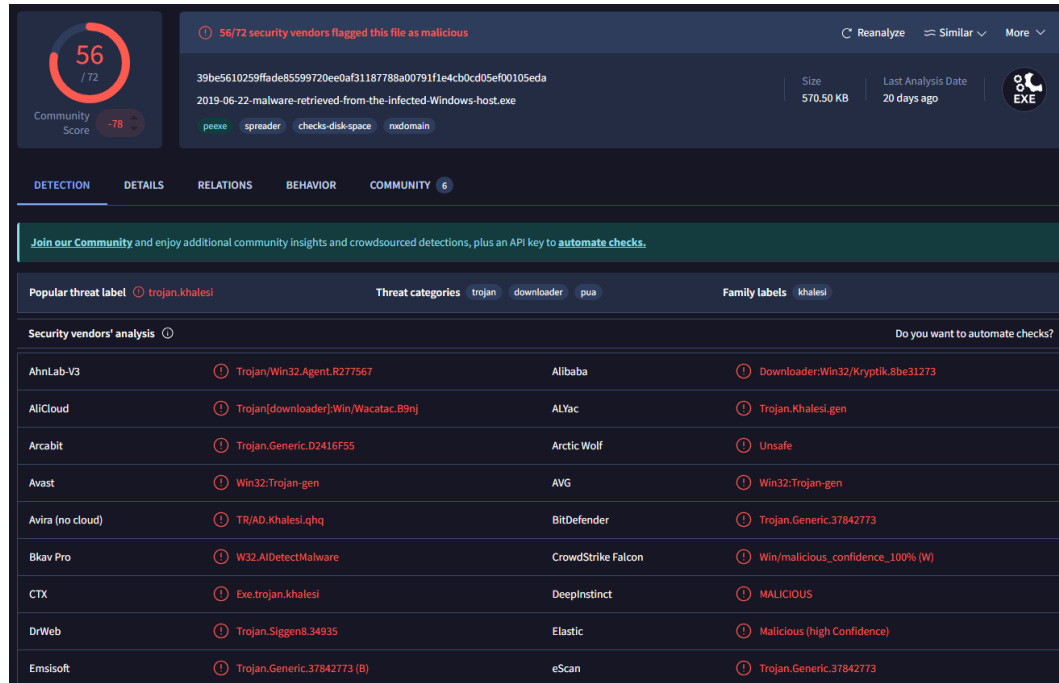


Figura 12 Verificação do nível de perigo deste ficheiro malware usando o site vírus total

For added security, once the exercise is done, you can remove the malware file from the virtual machine to avoid accidental viruses on your machine.

Exercise 5: Type of Malware that infected the machine

Based on the analyzed traffic alerts, the Windows system has been infected by an information-stealing Trojan, specifically the variant known as KPOT Stealer.

Src IP	SPort	Dst IP	DPort	Pr	Event Message
35.226.156.55	443	10.0.76.193	49207	6	ET POLICY Lets Encrypt Free SSL Cert Observed
10.0.76.109	49204	37.46.135.170	80	6	ET CURRENT_EVENTS RIG EK URI Struct Jun 13 2017
37.46.135.170	80	10.0.76.109	49204	6	ETPRO CURRENT_EVENTS RIG EK Landing Apr 04 2017 M5
37.46.135.170	80	10.0.76.109	49204	6	ET INFO Suspicious Possible CollectGarbage in base64 1
37.46.135.170	80	10.0.76.109	49204	6	ET INFO Obfuscated fromCharCode
10.0.76.109	49203	37.46.135.170	80	6	ET CURRENT_EVENTS RIG EK URI Struct Mar 13 2017 M2
10.0.76.109	49203	37.46.135.170	80	6	ET POLICY Outdated Flash Version M1
37.46.135.170	80	10.0.76.109	49203	6	ETPRO CURRENT_EVENTS RIG EK Flash Exploit Sep 05 2017 (FWS)
10.0.76.109	49209	8.209.83.76	80	6	ET TROJAN Generic gate[.].php GET with minimal headers
10.0.76.109	49211	8.209.83.76	80	6	ET TROJAN Trojan Generic - POST To gate.php with no referer
10.0.76.109	49211	8.209.83.76	80	6	ETPRO TROJAN KPOT Stealer Exfiltration M2
10.0.76.109	49211	8.209.83.76	80	6	ET TROJAN Trojan Generic - POST To gate.php with no accept headers
74.125.138.1...	80	10.0.76.193	49216	6	GPL WEB_CLIENT web bug 0x0 gif attempt
35.226.156.55	80	10.0.76.193	49261	6	GPL WEB_CLIENT web bug 0x0 gif attempt

Figura 1 Alertas encontrado no tráfego

Figura 13 Alertas encontrados no tráfego fornecidos pelo formador

The identification is confirmed by the specific security alert:

- ETPRO TROJAN KPOT Stealer Exfiltration M2

This alert is generated when the malware initiates data-stealing activities, being a trusted signature for positive identification of the KPOT Stealer.

Operation Method:

- Establishes communication with Command and Control (C2) servers.
- Uses discreet exfiltration techniques to avoid detection.
- Stores data temporarily before sending.
- Uses specific endpoints as gate.php for communication.

Exercise 6: IP of the host that infected the machine

As mentioned earlier, the IP of the host that infected the machine is 37.46.135.170 seen in traffic alerts.

One can also consider the IP 8.209.83.76 as the host that helped in the infection of the machine.

Exercise 7: Domain of the host that infected the machine

To find the various available domains I will use the "dns.qry.name" filter, when looking at the "Info" column I will look for suspicious domains.

I didn't end up finding the domain of 37.46.135.170, but I found a suspicious domain fghjkmgru34.site which is the domain of IP 8.209.83.76, the host that receives the stolen data and helped in the infection of the system.

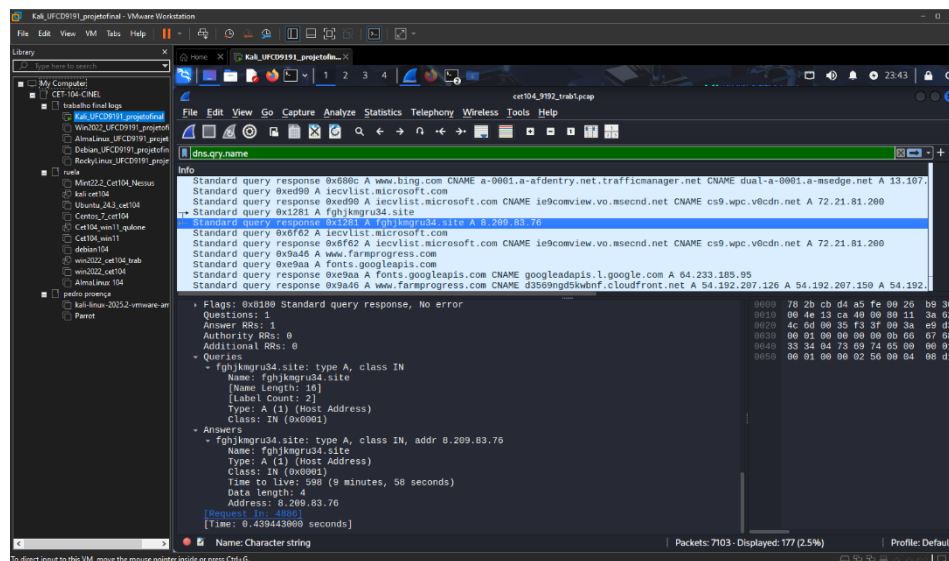


Figura 14 Domínio do host que infetou a máquina

Bibliography

Sources of information used:

- Recordings of the classes,
- Notes / Challenges made,

This work also takes a lot of inspiration from my two previous final works on Linux because they are similar in structure.

Conclusion

This work allowed me to achieve the proposed objectives, obtaining practical and theoretical knowledge in forensic analysis and investigation of security incidents.

The analysis of the PCAP file was essential to understand the entire attack, from the moment the computer was infected to the communications it made with the hackers' servers. The safe extraction of SHA256 from the executable provided a critical compromise indicator for future detections.

As for the methods used, the following stand out:

Wireshark: Indispensable tool for detailed analysis of network traffic, allowing you to filter and follow specific communication flows.

Static Analysis: Secure approach to extracting metadata and indicators from malicious files without risk of accidental execution.

Forensic Methodology: A structured process for collecting, analyzing, and documenting evidence in a reproducible way.

In summary, the results confirm that network traffic analysis is an essential component of IT security, allowing not only to detect malicious activities in real time, but also to investigate security incidents retrospectively.